PES UNIVERSITY

Department of Computer Science & Engineering

Information Security

UE23CS343BB6

Threat Modeling Exercise Submission

Name of the Student	Pranav Hemanth
SRN	PES1UG23CS433
Section	G
Department	CSE
Campus	RR

Threat Modeling Exercise

Department of Computer Science & Engineering
Information Security

UE23CS343BB6

Threat Modelling Case Study Example:

The Ankle Monitor Predictor of Stroke (AMPS)

This section contains a high-level feature overview document for the **Ankle Monitor Predictor of Stroke** (**AMPS**) system. This system is a home use medical device for a fictional stroke diagnostic technique. This is a fictional example to highlight typical features encountered when threat modelling medical devices.

The Ankle Monitor Predictor of Stroke System:

AMPS is a home use medical device worn at night (or when resting) by patients considered at risk for a stroke. The AMPS system gathers medical readings that can be later analyzed by a medical professional.

While the system can help predict a patient's risk of experiencing a stroke, it does not alert—and is not intended to alert—if a stroke is imminent or occurring.

- Period of expected use: One to three months
- Medical capability: Diagnostic only
- Device invasiveness: Low (easily removable, like a wristwatch)

AMPS Core Use Case:

Alice has been informed by her doctor, based on her family history and several other risk factors, that she is at increased risk of experiencing a stroke. To gain further insight and determine a treatment plan, her doctor has instructed her to take the AMPS system home and wear it when she sleeps to take readings.

She is also directed to install a companion app on her phone that will connect to the AMPS system (via Bluetooth) and upload the readings every day to the AMPS cloud service, where they will be analyzed by an automated algorithm. Alice's doctor will check the results after the first week to identify any immediate

causes of concern, and they will schedule a follow-up consult in two months.

AMPS Core Technology:

- A Bluetooth Low Energy (BLE)-enabled ankle monitor that takes physiological measurements from the patient
- A phone/tablet application (app) for patients to pair with their ankle monitor that will display readings and communicate with the cloud services
- AMPSCS: The Ankle Monitor Predictor of Stroke Cloud Service

AMPS device:

AMPS is a health monitoring system worn on a patient's ankle when they are resting. It has the following specifications and capabilities:

- Weight: 0.13kg
- Power source: Lithium-ion battery recharged via universal serial bus (USB) C cable. Provides up to 96 hours of usage under normal circumstances
- On/off switch
- Physical Bluetooth pairing button
- Proprietary stroke-predicting sensor. Note: The sensor that requires contact with a patient's skin.
- Heart rate monitor
- Body temperature sensor
- Bluetooth Low Energy (BLE) connectivity
- Onboard computer and flash storage that can store up to two weeks of patient data for later transmission

Patient App:

There are two different versions of the patient app, one for Apple iOS, and another for Android devices.

Both apps contain the following functionality:

- The app is downloaded by the patient via Google Play or the Apple app store.
- It can pair with the AMPS device via Bluetooth.
- It contains an interface for a patient to create an account with the AMPS cloud services, register an AMPS device, and authorize clinicians to view their data.
- If the patient gives permission to the app, it will automatically connect to the AMPS device once a day and upload readings to the AMPSCS. If the patient does not give it permission, the app will store the data retrieved from the AMPS device until a manual upload is initiated. The amount of data transferred per upload is typically less than 1 megabyte a day.
- The app will display status information to the patient, including the last time the app synced with the AMPSCS, a log of the days the app was able to pull data from the AMPS device, and a log listing if the AMPS device was successfully collecting data.
- There is a device management screen that primarily focuses on diagnosing Bluetooth connection problems, and common issues that may prevent the AMPS device from collecting data. In addition:
    - ⇒ The app can wipe patient data from the AMPS device.
    - ⇒ The app can check for and update the firmware of the AMPS device with new versions.
    - ⇒ The app can revert the AMPS device to factory default settings.
- If the device does not successfully sync to the cloud services once every 24 hours, an in-app notice will appear directing the patient to sync their data. After 72 hours have elapsed since a successful sync, the patient will be emailed an automatic reminder.

AMPS Cloud Service:

The AMPSCS is a collection of virtual machines hosted in a cloud infrastructure. It consists of the following functionality:

- An application gateway server to inspect and limit traffic going into the AMPSCS systems
- A set of backend services that perform analysis of the patient data
- A collection of patient-facing services that communicate with the patient app, provide a web portal for patients to register their AMPS device, and authorize clinicians to view their data
- A collection of health delivery organization (HDO)-facing services that provide a web portal for clinicians to create an account and access a patient's data
    - ⇒ Clinicians' access to the portal using a web browser.
    - ⇒ Authentication is provided via username and password.
    - ⇒ Clinician service identifiers that clinicians can provide to patients so the patients can authorize them through the app.
    - ⇒ The clinicians can view a summary of the patient's raw data and the analysis performed by the AMPSCS backend algorithms.
    - ⇒ The ability for clinicians to download a patient's data via an encrypted zip file.

Questions:

Question 1: What are we working on?

Draw the architecture diagram (high level). Then add details and trust boundaries. You can use DFD/Swim lane/ State diagrams.

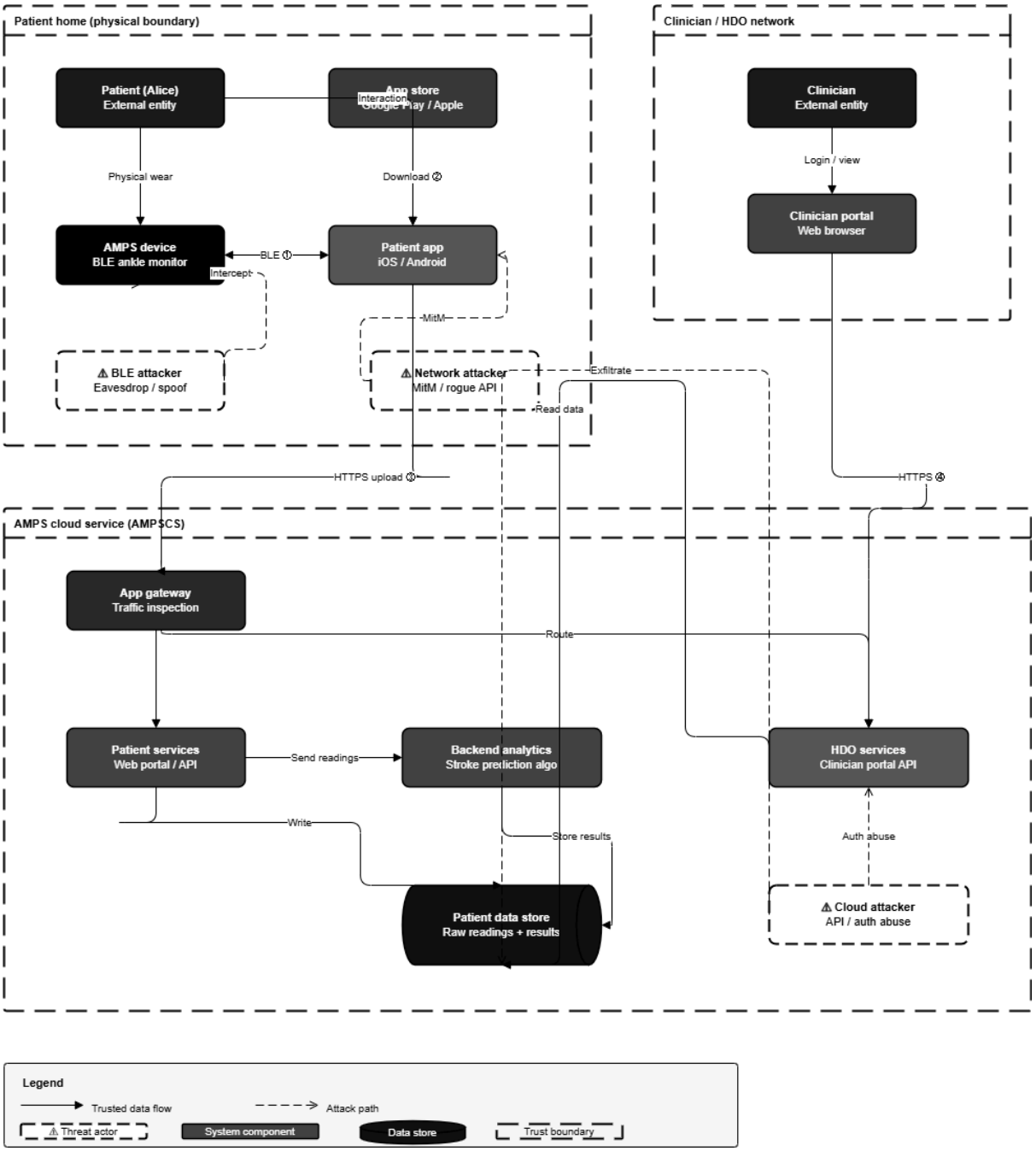
Answer: The system under analysis is the Ankle Monitor Predictor of Stroke (AMPS), a home-use medical device designed to collect physiological data from patients at risk of stroke. The system consists of four primary components: the AMPS wearable device, the patient mobile application, the AMPS Cloud Service (AMPSCS), and the clinician web portal.

The AMPS device collects health data such as heart rate and body temperature and stores it locally. This data is periodically transmitted to the patient's mobile application using Bluetooth Low Energy (BLE). The mobile application then uploads the data securely to the

cloud infrastructure, where it is processed and made accessible to clinicians through a web portal.

Assets Identified

- Patient health data (highly sensitive)
- Device firmware
- User credentials (patient and clinician)
- Cloud-stored medical records
- Communication channels (BLE and HTTPS)



Question 2: What can go wrong?

Use STRIDE to enumerate the risk / potential vulnerabilities etc.

Answer: STRIDE ANALYSIS

STRIDE	Component	Key Strengths	Key Weaknesses
Spoofing	AMPS Device	Physical pairing required	No strong device identity → impersonation possible
	Patient App	Distributed via signed stores	No certificate pinning; BLE not strongly authenticated
	Cloud (AMPSCS)	Gateway filters traffic	No mutual TLS / strong device-cloud auth
	Clinician Portal	Basic auth present	No MFA; shared credentials risk
	BLE Link	Physical pairing needed	Vulnerable legacy pairing; no re-authentication
Tampering	AMPS Device	Limited physical exposure	Firmware update path not secured
	Patient App	App store signing	Unsigned firmware possible via app
	Cloud	Server-side analytics	No integrity checks on uploaded data
	BLE Link	Short range	Weak/no encryption → data tampering possible
Repudiation	Patient App	Local logs exist	No reliable server-side verification
	Cloud	Server logs possible	No immutable logging / integrity guarantees

	BLE Link	—	No session logs; gaps indistinguishable
Information Disclosure	AMPS Device	Limited physical access	Data stored unencrypted
	Patient App	Access control exists	Local data + logs may leak info
	Cloud	Encrypted export	Misconfig or weak encryption risk
	Clinician Portal	Patient authorization required	No MFA → full data exposure risk
	BLE Link	Supports encryption	Eavesdropping if not enforced
Denial of Service	AMPS Device	Battery + local storage buffer	BLE jamming disrupts sync
	Patient App	Sync failure notifications	Background restrictions may silently stop sync
	Cloud	Rate limiting	Gateway bottleneck / DDoS risk
	Clinician Portal	Scalable infra	No lockout → brute force risk
	BLE Link	Auto reconnect	Easy to jam; no fallback channel
Elevation of Privilege	AMPS Device	Limited OS surface	Unauthenticated firmware update risk
	Patient App	OS sandboxing	Device management lacks step-up auth
	Cloud	Service separation	Lateral movement risk in shared infra

	Clinician Portal	Scoped access	No fine-grained RBAC
	BLE Link	Role separation	Device may accept unauthorized commands

Question 3: What are we going to do about it?

Eliminate, Mitigate, Accept or Transfer

Answer: Mitigation Strategies

Spoofing

- Implement strong authentication mechanisms such as multi-factor authentication.
- Use secure BLE pairing with authentication and bonding.

Tampering

- Encrypt all communication channels (BLE and HTTPS).
- Use digital signatures and code signing for firmware updates.
- Implement integrity verification using cryptographic hashes.

Repudiation

- Maintain secure audit logs for all system activities.
- Use timestamps and logging mechanisms to track access and actions.

Information Disclosure

- Encrypt data both at rest and in transit.
- Use secure API gateways with proper authentication and authorization.
- Apply least privilege access control.

Denial of Service

- Implement rate limiting and request throttling.
- Use load balancing and redundant cloud infrastructure.
- Validate all inputs to prevent crashes.

Elevation of Privilege

- Enforce role-based access control (RBAC).
- Conduct regular security audits and penetration testing.

- Keep systems updated with security patches.

Risk Treatment Decisions

- High-risk threats such as data leakage and spoofing are mitigated.
- Critical risks such as firmware tampering are eliminated through secure design.
- Low-impact risks such as minor service disruptions may be accepted.
- Infrastructure-related risks may be transferred to cloud service providers through SLAs.

Question 4: Did we do a good job?

Answer: The threat modeling exercise successfully identifies the major components, assets, and trust boundaries of the AMPS system. The use of the STRIDE framework ensures systematic identification of threats across all layers of the system.

The model provides comprehensive coverage of key risks, including data security, authentication, communication channels, and cloud infrastructure. Appropriate mitigation strategies have been proposed for each category of threat, improving the overall security posture of the system.

However, there are some limitations. The analysis is high-level and does not include detailed cryptographic validation or real-world attack simulations. Additionally, assumptions have been made regarding the security of the cloud infrastructure and third-party services.

Overall, the threat model is effective as a foundational security analysis. Further improvements can include penetration testing, formal verification of protocols, and compliance checks with healthcare security standards such as HIPAA.